

ISO/IEC 27001:2022

Questionnaire d'Audit de Sécurité de l'Information

Classé par Rôles — Strictement selon les Clauses 4 à 10 et l'Annexe A

Rôle	Clauses ISO 27001	Nb Questions
Direction Générale / Top Management	§ 4, 5, 6, 9, 10	38
RSSI / Responsable Sécurité SI	§ 6.1, 8, 9.1 + Annexe A	42
Équipe IT / Administrateurs Systèmes & Réseaux	§ 7.1, 8.1 + Annexe A.7, A.8	35
Ressources Humaines / Administration du Personnel	§ 7.2, 7.3, 7.4 + Annexe A.6	22
Auditeur Interne / Responsable Conformité	§ 7.5, 9.2, 10.1	20
EMPLOYEE_ADMIN	§ 6.1, 8.1 + Annexe A.5	25

Légende des réponses :

C	Conforme — exigence pleinement satisfaite	NC	Non Conforme — écart constaté, action corrective requise
PC	Partiellement Conforme — en cours de mise en œuvre	NA	Non Applicable — mesure exclue avec justification

Organisation : _____

Date d'audit : _____

Périmètre audité : _____

Réf. du rapport : _____

Direction Générale / Top Management

§ 4, 5, 6, 9, 10

Leadership, politique de sécurité, objectifs, revue de direction, amélioration continue

Total : **38 questions** — réparties sur 5 clause(s)/groupe(s)

§ 4 — Contexte de l'organisation

7 questions

§4.1 Enjeux internes/externes | §4.2 Parties intéressées | §4.3 Domaine d'application | §4.4 SMSI

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
1	Avez-vous formellement identifié les enjeux internes et externes susceptibles d'affecter la capacité de l'organisation à atteindre les résultats attendus de son SMSI ?	§4.1		■	■	■	■
2	Ces enjeux sont-ils documentés et revus périodiquement ?	§4.1		■	■	■	■
3	Avez-vous identifié les parties intéressées pertinentes pour le SMSI (clients, régulateurs, partenaires, actionnaires...) ?	§4.2		■	■	■	■
4	Les exigences (légales, contractuelles, réglementaires) de ces parties intéressées sont-elles documentées et prises en compte ?	§4.2		■	■	■	■
5	Le périmètre du SMSI (domaine d'application) est-il formellement défini, documenté et approuvé par la direction ?	§4.3		■	■	■	■
6	Les interfaces et dépendances avec des entités hors périmètre sont-elles prises en compte dans la définition du domaine d'application ?	§4.3		■	■	■	■
7	Le SMSI est-il établi, mis en œuvre, tenu à jour et amélioré en continu conformément aux exigences de la norme ?	§4.4		■	■	■	■

Observations / Commentaires :

§ 5 — Leadership et engagement

12 questions

§5.1 Leadership | §5.2 Politique | §5.3 Rôles et responsabilités

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
8	La direction démontre-t-elle son leadership en assumant la responsabilité de l'efficacité du SMSI ?	§5.1		■	■	■	■
9	La politique de sécurité de l'information est-elle établie, documentée, approuvée et signée par la direction ?	§5.1/5.2		■	■	■	■
10	La politique est-elle cohérente avec l'orientation stratégique de l'organisation ?	§5.2		■	■	■	■
11	La politique inclut-elle des objectifs de sécurité ou fournit-elle un cadre pour les fixer ?	§5.2		■	■	■	■
12	La politique comprend-elle un engagement à satisfaire aux exigences applicables ?	§5.2		■	■	■	■
13	La politique comprend-elle un engagement envers l'amélioration continue du SMSI ?	§5.2		■	■	■	■
14	La politique est-elle disponible sous forme d'information documentée et communiquée en interne ?	§5.2		■	■	■	■

15	La politique est-elle disponible pour les parties intéressées externes, le cas échéant ?	§5.2		■	■	■	■
16	Les rôles et responsabilités liés à la sécurité de l'information sont-ils formellement attribués et communiqués ?	§5.3		■	■	■	■
17	La direction s'assure-t-elle que le SMSI atteint les résultats attendus et rend compte de sa performance ?	§5.1		■	■	■	■
18	La direction promeut-elle activement l'amélioration continue au sein de l'organisation ?	§5.1		■	■	■	■
19	La direction soutient-elle les autres rôles de management afin de démontrer leur leadership dans leur domaine de responsabilité ?	§5.1		■	■	■	■

Observations / Commentaires :

§ 6 — Planification — Objectifs de sécurité

5 questions

§6.1.1 Risques et opportunités | §6.2 Objectifs

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
20	Des objectifs de sécurité de l'information sont-ils établis pour les fonctions et niveaux pertinents de l'organisation ?	§6.2		■	■	■	■
21	Les objectifs sont-ils mesurables, cohérents avec la politique et tenant compte des résultats de l'appréciation des risques ?	§6.2		■	■	■	■
22	Les objectifs de sécurité sont-ils documentés et communiqués ?	§6.2		■	■	■	■
23	Existe-t-il un plan précisant : ce qui sera fait, les ressources requises, les responsables, les délais et comment les résultats seront évalués ?	§6.2		■	■	■	■
24	La direction a-t-elle planifié des actions pour traiter les risques et opportunités identifiés dans le cadre du SMSI ?	§6.1.1		■	■	■	■

Observations / Commentaires :

§ 9.3 — Revue de direction

9 questions

§9.3.1 Entrées | §9.3.2 Éléments de revue | §9.3.3 Résultats

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
25	La direction réalise-t-elle des revues du SMSI à des intervalles planifiés ?	§9.3		■	■	■	■
26	La revue inclut-elle l'état d'avancement des actions décidées lors des revues précédentes ?	§9.3.1		■	■	■	■
27	La revue inclut-elle les changements des enjeux internes et externes pertinents pour le SMSI ?	§9.3.2		■	■	■	■
28	La revue inclut-elle les retours sur la performance de la sécurité (non-conformités, indicateurs, résultats de surveillance et d'audit) ?	§9.3.2		■	■	■	■
29	La revue inclut-elle le retour des parties intéressées ?	§9.3.2		■	■	■	■

30	La revue inclut-elle les résultats de l'appréciation des risques et l'état du plan de traitement des risques ?	§9.3.2		■	■	■	■
31	La revue inclut-elle les opportunités d'amélioration continue ?	§9.3.2		■	■	■	■
32	Les résultats de la revue de direction sont-ils documentés et conservés comme information documentée ?	§9.3.3		■	■	■	■
33	Les décisions de la revue portent-elles sur les opportunités d'amélioration et les besoins de changement du SMSI, y compris les ressources nécessaires ?	§9.3.3		■	■	■	■

Observations / Commentaires :

§ 10 — Amélioration continue

5 questions

§10.1 Non-conformité et actions correctives | §10.2 Amélioration continue

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
34	L'organisation améliore-t-elle en continu la pertinence, l'adéquation et l'efficacité du SMSI ?	§10.2		■	■	■	■
35	Lorsqu'une non-conformité survient, l'organisation réagit-elle pour la maîtriser et en corriger les effets ?	§10.1		■	■	■	■
36	Les causes des non-conformités sont-elles analysées afin qu'elles ne se reproduisent pas ou n'apparaissent pas ailleurs ?	§10.1		■	■	■	■
37	Les actions correctives sont-elles proportionnées aux effets des non-conformités rencontrées ?	§10.1		■	■	■	■
38	L'efficacité des actions correctives est-elle évaluée et les résultats documentés ?	§10.1		■	■	■	■

Observations / Commentaires :

RSSI / Responsable Sécurité SI

§ 6.1, 8, 9.1 +
Annexe A

Appréciation et traitement des risques, mise en œuvre des mesures, surveillance opérationnelle, Déclaration d'Applicabilité

Total : 42 questions — réparties sur 4 clause(s)/groupe(s)

§ 6.1 — Appréciation et traitement des risques

14 questions

§6.1.2 Appréciation des risques | §6.1.3 Traitement des risques

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
1	Un processus d'appréciation des risques de sécurité de l'information est-il défini et documenté ?	§6.1.2a		■	■	■	■
2	Des critères d'appréciation et d'acceptation du risque sont-ils établis et maintenus ?	§6.1.2a		■	■	■	■
3	Le processus garantit-il que des appréciations répétées produisent des résultats cohérents, valides et comparables ?	§6.1.2b		■	■	■	■
4	Les risques sont-ils identifiés avec leurs propriétaires, ainsi que les conséquences potentielles sur la confidentialité, l'intégrité et la disponibilité ?	§6.1.2c		■	■	■	■
5	Les niveaux de risque sont-ils analysés (vraisemblance et conséquences) ?	§6.1.2d		■	■	■	■
6	Les risques sont-ils évalués par rapport aux critères établis afin de les hiérarchiser pour le traitement ?	§6.1.2e		■	■	■	■
7	Des informations documentées sur le processus et les résultats de l'appréciation des risques sont-elles conservées ?	§6.1.2f		■	■	■	■
8	Un processus de traitement des risques est-il défini et les options de traitement (modifier, retenir, éviter, transférer) sélectionnées ?	§6.1.3a		■	■	■	■
9	Les mesures nécessaires à la mise en œuvre de l'option de traitement choisie sont-elles déterminées et comparées à l'Annexe A de la norme ?	§6.1.3c		■	■	■	■
10	Une Déclaration d'Applicabilité (DdA) est-elle produite, incluant les mesures retenues et exclues avec justifications ?	§6.1.3d		■	■	■	■
11	Un plan de traitement des risques est-il formalisé et soumis à l'approbation des propriétaires de risques ?	§6.1.3e		■	■	■	■
12	Les propriétaires de risques ont-ils approuvé le plan de traitement et accepté le niveau de risque résiduel ?	§6.1.3f		■	■	■	■
13	Des informations documentées sur le processus et les résultats du traitement des risques sont-elles conservées ?	§6.1.3g		■	■	■	■
14	L'appréciation des risques est-elle renouvelée à intervalles planifiés et lors de changements significatifs ou proposés ?	§8.2		■	■	■	■

Observations / Commentaires :

§ 8 — Mise en œuvre opérationnelle du SMSI

8 questions

§8.1 Planification et maîtrise | §8.2 Appréciation des risques | §8.3 Traitement des risques

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
15	Les processus nécessaires pour répondre aux exigences du SMSI sont-ils planifiés, mis en œuvre et maîtrisés ?	§8.1		■	■	■	■
16	Des critères pour les processus sont-ils définis et les processus exécutés conformément à ces critères ?	§8.1		■	■	■	■
17	Les informations documentées nécessaires pour démontrer que les processus ont été réalisés comme prévu sont-elles conservées ?	§8.1		■	■	■	■
18	Les processus externalisés pertinents pour le SMSI sont-ils identifiés et maîtrisés ?	§8.1		■	■	■	■
19	L'appréciation des risques est-elle réalisée à intervalles planifiés ou lorsque des changements significatifs sont proposés ou surviennent ?	§8.2		■	■	■	■
20	Le plan de traitement des risques est-il mis en œuvre et son état de réalisation suivi ?	§8.3		■	■	■	■
21	Les résultats du traitement des risques sont-ils documentés comme information documentée ?	§8.3		■	■	■	■
22	Les changements planifiés sont-ils maîtrisés et les conséquences de changements non intentionnels examinées, avec actions correctives si nécessaire ?	§8.1		■	■	■	■

Observations / Commentaires :

§ 9.1 — Surveillance, mesure, analyse et évaluation

8 questions

§9.1 Performance et efficacité du SMSI

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
23	L'organisation évalue-t-elle la performance de la sécurité de l'information et l'efficacité du SMSI ?	§9.1		■	■	■	■
24	Ce qui doit être surveillé et mesuré est-il déterminé (y compris processus et mesures de sécurité) ?	§9.1		■	■	■	■
25	Les méthodes de surveillance, mesure, analyse et évaluation sont-elles définies pour produire des résultats valides et comparables ?	§9.1		■	■	■	■
26	Quand la surveillance et la mesure doivent être effectuées est-il spécifié ?	§9.1		■	■	■	■
27	Qui doit effectuer la surveillance et la mesure est-il défini ?	§9.1		■	■	■	■
28	Quand les résultats de la surveillance et de la mesure doivent être analysés et évalués est-il précisé ?	§9.1		■	■	■	■
29	Qui doit analyser et évaluer ces résultats est-il identifié ?	§9.1		■	■	■	■
30	Des informations documentées permettant de prouver les résultats de surveillance et mesure sont-elles conservées ?	§9.1		■	■	■	■

Observations / Commentaires :

Annexe A — Déclaration d'Applicabilité & mesures de sécurité

12 questions

§6.1.3 DdA | Annexe A (93 mesures ISO 27001:2022)

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
31	Toutes les mesures de l'Annexe A ont-elles été examinées pour déterminer si elles sont applicables à l'organisation ?	§6.1.3/A		■	■	■	■
32	Pour les mesures exclues, une justification explicite est-elle fournie dans la Déclaration d'Applicabilité ?	§6.1.3d		■	■	■	■
33	Des politiques de sécurité thématiques sont-elles définies, approuvées par la direction et communiquées aux personnes concernées ?	A.5.1		■	■	■	■
34	Un processus de retour d'expérience sur les incidents de sécurité est-il en place et alimente-t-il la revue des mesures ?	A.5.27		■	■	■	■
35	Des rôles et responsabilités en matière de sécurité sont-ils définis, attribués et communiqués ?	A.5.2		■	■	■	■
36	Un inventaire des actifs informationnels est-il maintenu et chaque actif a-t-il un propriétaire désigné ?	A.5.9/5.10		■	■	■	■
37	Une classification de l'information est-elle définie et appliquée en fonction des besoins de l'organisation ?	A.5.12/5.13		■	■	■	■
38	Des procédures de gestion des incidents de sécurité sont-elles en place, documentées et testées ?	A.5.24–5.28		■	■	■	■
39	Un processus de gestion des vulnérabilités techniques est-il mis en œuvre et régulièrement exécuté ?	A.8.8		■	■	■	■
40	Des tests d'intrusion ou audits techniques sont-ils réalisés pour vérifier l'efficacité des mesures de sécurité ?	A.8.8		■	■	■	■
41	La continuité de la sécurité de l'information est-elle planifiée, mise en œuvre et testée ?	A.5.29/5.30		■	■	■	■
42	Les exigences légales, réglementaires et contractuelles relatives à la sécurité de l'information sont-elles identifiées et respectées ?	A.5.31/5.34		■	■	■	■

Observations / Commentaires :

Équipe IT / Administrateurs Systèmes & Réseaux

§ 7.1, 8.1 + Annexe
A.7, A.8

Mise en œuvre des mesures techniques et physiques de sécurité — accès, chiffrement, sauvegardes, journaux, infrastructure

Total : 35 questions — réparties sur 3 clause(s)/groupe(s)

§ 7.1 — Ressources et infrastructure

3 questions

§7.1 Ressources pour le SMSI

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
1	Les ressources nécessaires à l'établissement, la mise en œuvre, la tenue à jour et l'amélioration continue du SMSI sont-elles déterminées et fournies ?	§7.1		■	■	■	■
2	L'infrastructure informatique (réseaux, serveurs, postes de travail) est-elle documentée et incluse dans le périmètre du SMSI ?	§7.1/A.5.9		■	■	■	■
3	Les ressources allouées à la sécurité (outils, licences, personnel) sont-elles suffisantes pour atteindre les objectifs du SMSI ?	§7.1		■	■	■	■

Observations / Commentaires :

Annexe A.8 — Mesures de sécurité technologiques

22 questions

A.8.1 à A.8.34 — Contrôles des actifs technologiques

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
4	Un inventaire complet des actifs technologiques (matériels, logiciels, données) est-il maintenu à jour ?	A.5.9		■	■	■	■
5	Des droits d'accès sont-ils gérés selon le principe du moindre privilège (enregistrement, modification, révocation) ?	A.5.15/A.8.2		■	■	■	■
6	Des comptes d'accès privilégiés (administrateurs) sont-ils identifiés, gérés et revus régulièrement ?	A.8.2		■	■	■	■
7	Des informations d'authentification secrètes font-elles l'objet de mesures spécifiques (politique de mot de passe fort, MFA) ?	A.5.17/A.8.5		■	■	■	■
8	Les droits d'accès sont-ils revus à intervalles réguliers et lors de changements de poste ou de départ ?	A.5.18		■	■	■	■
9	Des mesures de protection contre les logiciels malveillants sont-elles en place et maintenues à jour ?	A.8.7		■	■	■	■
10	Un processus de gestion des vulnérabilités techniques et des correctifs est-il défini et appliqué dans les délais fixés par la politique ?	A.8.8		■	■	■	■
11	Les configurations sécurisées (durcissement) des systèmes sont-elles définies, documentées et appliquées ?	A.8.9		■	■	■	■
12	Les informations sensibles sont-elles chiffrées en transit et au repos conformément à une politique de chiffrement approuvée ?	A.8.24		■	■	■	■

13	Des sauvegardes régulières sont-elles effectuées, testées périodiquement et stockées conformément aux exigences de la politique ?	A.8.13		■	■	■	■
14	Des journaux d'événements (logs) sont-ils générés, protégés contre la modification et conservés selon les durées définies ?	A.8.15/8.17		■	■	■	■
15	Les horloges des systèmes d'information sont-elles synchronisées sur une source de temps de référence approuvée ?	A.8.17		■	■	■	■
16	Des mesures de segmentation et filtrage réseau sont-elles mises en œuvre pour isoler les environnements sensibles ?	A.8.22		■	■	■	■
17	L'installation de logiciels sur les systèmes en production est-elle soumise à une procédure d'autorisation formelle ?	A.8.19		■	■	■	■
18	Des environnements de développement, de test et de production sont-ils séparés et distincts ?	A.8.31		■	■	■	■
19	Des tests de sécurité (revue de code, tests d'intrusion) sont-ils effectués avant la mise en production de nouvelles applications ?	A.8.29		■	■	■	■
20	Les connexions à des réseaux externes sont-elles l'objet de mesures de filtrage (pare-feux, proxies) documentées ?	A.8.21/8.22		■	■	■	■
21	Une procédure de suppression ou réutilisation sécurisée des supports et équipements est-elle définie et appliquée ?	A.7.10/8.10		■	■	■	■
22	L'accès à distance (VPN, RDP, etc.) est-il authentifié, chiffré et journalisé ?	A.8.20/5.14		■	■	■	■
23	Les données à caractère personnel et données sensibles sont-elles traitées conformément à la politique de classification et aux exigences légales ?	A.5.34/8.11		■	■	■	■
24	Un processus de gestion des incidents de sécurité (détection, signalement, réponse) est-il formalisé et connu de l'équipe IT ?	A.5.24/5.25		■	■	■	■
25	Les preuves relatives aux incidents de sécurité sont-elles collectées et conservées de manière à préserver leur intégrité ?	A.5.28		■	■	■	■

Observations / Commentaires :

Annexe A.7 — Mesures de sécurité physiques et environnementales

10 questions

A.7.1 à A.7.14 — Protection physique des équipements et des locaux

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
26	Des périmètres de sécurité physique sont-ils définis pour protéger les zones contenant des informations et les équipements critiques (data center, salle serveur) ?	A.7.1		■	■	■	■
27	L'accès physique aux zones sécurisées est-il contrôlé (badges, biométrie, gardiennage) et journalisé ?	A.7.2/7.4		■	■	■	■
28	Les équipements sont-ils protégés contre les menaces environnementales (incendie, inondation, coupure d'alimentation) ?	A.7.5/7.11		■	■	■	■

29	Des alimentations électriques de secours (onduleurs, groupes électrogènes) sont-elles en place et testées régulièrement ?	A.7.11		■	■	■	■
30	Les supports contenant des informations sensibles sont-ils détruits de manière sécurisée lorsqu'ils ne sont plus nécessaires ?	A.7.10		■	■	■	■
31	Les équipements emportés hors des locaux font-ils l'objet de mesures de protection appropriées ?	A.7.9		■	■	■	■
32	Les câblages informatiques et électriques sont-ils protégés contre les interceptions ou les dommages physiques ?	A.7.12		■	■	■	■
33	Une maintenance régulière des équipements est-elle effectuée et documentée ?	A.7.13		■	■	■	■
34	Le travail dans les zones sécurisées fait-il l'objet de règles particulières (interdiction de photos, supervision des visiteurs) ?	A.7.3		■	■	■	■
35	Une politique 'bureau propre / écran vide' est-elle définie et son respect vérifié ?	A.7.7		■	■	■	■
Observations / Commentaires :							

Ressources Humaines / Administration du Personnel

§ 7.2, 7.3, 7.4 +
Annexe A.6

Compétences, sensibilisation, communication, obligations contractuelles, gestion du cycle de vie du personnel

Total : 22 questions — réparties sur 4 clause(s)/groupe(s)

§ 7.2 — Compétences

5 questions

§7.2 Compétences requises pour le SMSI

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
1	Les compétences nécessaires aux personnes dont le travail affecte la performance de sécurité de l'information sont-elles déterminées ?	§7.2		■	■	■	■
2	Ces personnes sont-elles compétentes sur la base d'une formation, d'études ou d'une expérience appropriées ?	§7.2		■	■	■	■
3	Des actions sont-elles menées pour acquérir les compétences nécessaires (formations, recrutements) et leur efficacité évaluée ?	§7.2		■	■	■	■
4	Des informations documentées (enregistrements de formation, diplômes, certifications) sont-elles conservées comme preuves de compétence ?	§7.2		■	■	■	■
5	Les compétences en sécurité de l'information sont-elles intégrées dans les descriptions de poste et les évaluations du personnel ?	§7.2/A.6.2		■	■	■	■

Observations / Commentaires :

§ 7.3 — Sensibilisation

5 questions

§7.3 Sensibilisation à la sécurité de l'information

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
6	Les personnes travaillant sous le contrôle de l'organisation ont-elles conscience de la politique de sécurité de l'information ?	§7.3		■	■	■	■
7	Le personnel comprend-il sa contribution à l'efficacité du SMSI et les bénéfices d'une amélioration des performances de sécurité ?	§7.3		■	■	■	■
8	Le personnel est-il conscient des implications d'un non-respect des exigences du SMSI ?	§7.3		■	■	■	■
9	Un programme de sensibilisation à la sécurité est-il mis en place, planifié annuellement et son contenu régulièrement mis à jour ?	§7.3/A.6.3		■	■	■	■
10	L'efficacité des actions de sensibilisation est-elle évaluée (tests de phishing simulés, quiz, évaluations) ?	§7.3/A.6.3		■	■	■	■

Observations / Commentaires :

§ 7.4 — Communication

3 questions

§7.4 Besoins de communication interne et externe

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
11	Les besoins de communication interne et externe pertinents pour le SMSI sont-ils déterminés (quoi, quand, à qui, comment) ?	§7.4		■	■	■	■
12	Les informations relatives à la sécurité sont-elles communiquées aux parties concernées de manière opportune ?	§7.4		■	■	■	■
13	Les modalités de communication en cas d'incident de sécurité sont-elles connues de tous les employés ?	§7.4/A.5.2 4		■	■	■	■

Observations / Commentaires :

Annexe A.6 — Mesures liées aux personnes

9 questions

A.6.1 à A.6.8 — Sécurité des ressources humaines

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
14	Des vérifications des antécédents sont-elles effectuées avant l'embauche, conformément aux lois et règlements applicables ?	A.6.1		■	■	■	■
15	Les termes et conditions d'emploi incluent-ils les responsabilités de l'employé et de l'organisation en matière de sécurité de l'information ?	A.6.2		■	■	■	■
16	Tous les employés et sous-traitants respectent-ils et appliquent-ils la politique de sécurité de l'information de l'organisation ?	A.6.4		■	■	■	■
17	Un processus disciplinaire formel est-il défini et communiqué pour les manquements à la sécurité de l'information ?	A.6.4		■	■	■	■
18	Les responsabilités en matière de sécurité de l'information sont-elles maintenues après la fin du contrat ou d'un changement de poste ?	A.6.5		■	■	■	■
19	Les accès sont-ils révoqués et les équipements récupérés lors de la fin ou du changement de poste d'un employé ?	A.6.5		■	■	■	■
20	Un accord de confidentialité ou de non-divulgence est-il signé par chaque employé et sous-traitant ayant accès à des informations sensibles ?	A.6.6		■	■	■	■
21	Des règles et mesures de sécurité pour le télétravail sont-elles définies et appliquées ?	A.6.7		■	■	■	■
22	Les employés sont-ils informés et tenus de signaler tout événement ou faiblesse lié à la sécurité de l'information observé ?	A.6.8		■	■	■	■

Observations / Commentaires :

Auditeur Interne / Responsable Conformité

§ 7.5, 9.2, 10.1

Information documentée, programme d'audit interne, évaluation de conformité, non-conformités et actions correctives

Total : 20 questions — réparties sur 3 clause(s)/groupe(s)

§ 7.5 — Information documentée

7 questions

§7.5.1 Généralités | §7.5.2 Création et mise à jour | §7.5.3 Maîtrise

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
1	Le SMSI inclut-il l'information documentée exigée par la norme ISO/IEC 27001 ?	§7.5.1		■	■	■	■
2	L'organisation a-t-elle déterminé et inclus l'information documentée jugée nécessaire à l'efficacité du SMSI ?	§7.5.1		■	■	■	■
3	Lors de la création et mise à jour de l'information documentée, les aspects d'identification, de format, de support et de revue/approbation sont-ils assurés ?	§7.5.2		■	■	■	■
4	L'information documentée est-elle disponible et utilisable aux endroits et au moment où elle est nécessaire ?	§7.5.3		■	■	■	■
5	L'information documentée est-elle convenablement protégée (contre la divulgation non autorisée, le mauvais usage ou la perte d'intégrité) ?	§7.5.3		■	■	■	■
6	La distribution, l'accès, la récupération, l'utilisation, le stockage, la conservation et l'élimination de l'information documentée sont-ils maîtrisés ?	§7.5.3		■	■	■	■
7	L'information documentée d'origine externe jugée nécessaire pour le SMSI est-elle identifiée et son utilisation maîtrisée ?	§7.5.3		■	■	■	■

Observations / Commentaires :

§ 9.2 — Audit interne du SMSI

8 questions

§9.2.1 Objectifs | §9.2.2 Programme d'audit

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
8	L'organisation mène-t-elle des audits internes à des intervalles planifiés pour s'assurer que le SMSI est conforme aux exigences internes et à celles de la norme ?	§9.2.1		■	■	■	■
9	L'audit interne permet-il de vérifier si le SMSI est efficacement mis en œuvre et tenu à jour ?	§9.2.1		■	■	■	■
10	Un programme d'audit est-il planifié, établi, mis en œuvre et tenu à jour, en tenant compte de l'importance des processus et des résultats des audits précédents ?	§9.2.2		■	■	■	■
11	Les critères et le périmètre de chaque audit sont-ils définis ?	§9.2.2		■	■	■	■
12	Les auditeurs sélectionnés garantissent-ils l'objectivité et l'impartialité du processus d'audit (indépendance vis-à-vis de leur propre travail) ?	§9.2.2		■	■	■	■
13	Les résultats des audits sont-ils communiqués à la direction concernée ?	§9.2.2		■	■	■	■

14	Des informations documentées (rapports d'audit, registre des constatations) sont-elles conservées comme preuves du programme et des résultats d'audit ?	§9.2.2		■	■	■	■
15	Les actions correctives issues des audits précédents sont-elles suivies jusqu'à leur clôture ?	§9.2.2/10.1		■	■	■	■

Observations / Commentaires :

§ 10.1 — Non-conformité et actions correctives

5 questions

§10.1 Traitement des non-conformités

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
16	Un registre des non-conformités est-il maintenu avec les actions prises et les résultats des actions correctives ?	§10.1		■	■	■	■
17	Lorsqu'une non-conformité survient, l'organisation réagit-elle en temps opportun pour la maîtriser et corriger ses effets ?	§10.1		■	■	■	■
18	Une analyse des causes racines des non-conformités est-elle systématiquement menée ?	§10.1		■	■	■	■
19	L'efficacité des actions correctives mises en œuvre est-elle vérifiée et documentée ?	§10.1		■	■	■	■
20	Si nécessaire, des modifications du SMSI sont-elles apportées à la suite d'une non-conformité identifiée ?	§10.1		■	■	■	■

Observations / Commentaires :

EMPLOYEE_ADMIN**§ 6.1, 8.1 + Annexe A.5***Responsable d'une unité métier / département — propriété des risques, gestion des fournisseurs, maîtrise opérationnelle des processus*Total : **25 questions** — réparties sur 3 clause(s)/groupe(s)**§ 6.1 — Propriété des risques liés aux processus métier****6 questions***§6.1.2 Identification | §6.1.3 Traitement | §8.2 Réappréciation*

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
1	Êtes-vous formellement désigné comme propriétaire des risques liés aux actifs et processus sous votre responsabilité ?	§6.1.2		■	■	■	■
2	Avez-vous approuvé le plan de traitement des risques concernant vos processus et accepté le niveau de risque résiduel ?	§6.1.3f		■	■	■	■
3	Les risques liés à vos processus métier sont-ils réexaminés lors de changements significatifs (nouveaux projets, nouvelles applications, réorganisation) ?	§8.2		■	■	■	■
4	Les exigences de sécurité de l'information sont-elles prises en compte dès la conception des projets et applications métier ?	§6.1/A.8.2 5		■	■	■	■
5	Les actifs informationnels sous votre responsabilité sont-ils inventoriés, classifiés et correctement protégés selon leur niveau de sensibilité ?	A.5.9/5.12		■	■	■	■
6	Les exigences légales, réglementaires et contractuelles applicables à vos processus métier sont-elles identifiées et respectées ?	A.5.31/5.3 2		■	■	■	■

Observations / Commentaires :**Annexe A.5.19–5.22 — Sécurité des relations avec les fournisseurs****10 questions***A.5.19 Politique | A.5.20 Exigences | A.5.21 Chaîne ICT | A.5.22 Surveillance*

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
7	Une politique de sécurité de l'information pour les relations avec les fournisseurs est-elle définie et appliquée ?	A.5.19		■	■	■	■
8	Les exigences de sécurité pertinentes sont-elles établies et convenues avec chaque fournisseur qui accède à des informations ou systèmes de l'organisation ?	A.5.20		■	■	■	■
9	Les accords avec les fournisseurs incluent-ils des clauses sur la sécurité (confidentialité, niveaux de service, audits, gestion des incidents) ?	A.5.20		■	■	■	■
10	La chaîne d'approvisionnement ICT (produits et services technologiques) est-elle prise en compte dans la politique de sécurité des fournisseurs ?	A.5.21		■	■	■	■
11	La conformité des fournisseurs aux exigences de sécurité est-elle régulièrement surveillée, revue et auditée ?	A.5.22		■	■	■	■

12	Des changements dans les services fournis par les prestataires sont-ils gérés en tenant compte de la criticité des informations et systèmes concernés ?	A.5.22		■	■	■	■
13	Des procédures d'accueil et de départ des fournisseurs/prestataires définissant les règles de sécurité à respecter sont-elles en place ?	A.5.20/A.6.1		■	■	■	■
14	L'accès des prestataires aux systèmes d'information est-il strictement limité au périmètre nécessaire et journalisé ?	A.5.15/A.8.2		■	■	■	■
15	Les incidents de sécurité impliquant des fournisseurs sont-ils signalés et traités conformément à la procédure de gestion des incidents ?	A.5.24/5.2.2		■	■	■	■
16	Des évaluations de sécurité des fournisseurs critiques sont-elles réalisées avant tout engagement et périodiquement renouvelées ?	A.5.19/5.2.2		■	■	■	■

Observations / Commentaires :

§ 8.1 + Annexe A.5 — Maîtrise opérationnelle des processus métier

9 questions

§8.1 Planification | A.5.3 Séparation | A.5.29/5.30 Continuité

N°	Question	Réf.	Preuve / Observation	C	P C	N C	N A
17	Les processus métier incluent-ils des mesures de sécurité définies et documentées (procédures, modes opératoires) ?	§8.1		■	■	■	■
18	La séparation des tâches est-elle appliquée dans les processus sensibles pour réduire le risque de fraude ou d'erreur ?	A.5.3		■	■	■	■
19	Les droits d'accès des utilisateurs de vos équipes sont-ils revus et ajustés lors de changements de poste ou de départ ?	A.5.18		■	■	■	■
20	Vos équipes signalent-elles les événements de sécurité suspects (tentatives de phishing, comportements anormaux) ?	A.6.8		■	■	■	■
21	Les informations confidentielles de votre périmètre sont-elles traitées, transmises et stockées selon les règles de classification en vigueur ?	A.5.12/5.1.3		■	■	■	■
22	Des procédures de continuité d'activité (PCA) existent-elles pour vos processus critiques et sont-elles testées régulièrement ?	A.5.29/5.30		■	■	■	■
23	Les droits de propriété intellectuelle relatifs aux logiciels et contenus utilisés dans votre périmètre sont-ils respectés ?	A.5.33		■	■	■	■
24	Les données à caractère personnel traitées dans vos processus font-elles l'objet de mesures de protection conformes aux exigences légales ?	A.5.34		■	■	■	■
25	Une revue indépendante de la sécurité de l'information relative à vos processus est-elle réalisée à intervalles planifiés ?	A.5.35		■	■	■	■

Observations / Commentaires :

Signatures et Validation

Audit  (e) — Repr  sentant Direction

Nom :

Fonction :

Date :

Signature :

Auditeur / RSSI

Nom :

Fonction :

Date :

Signature :
